サイバーセキュリティ 3 レジュメ 1

2026 年 10 月 19 日

- 講義はオンデマンドもあり
- 成績は期末レポートのみ

目次

1 授業概要 2
1.1 講義情報・担当講師 . . . 2
1.2 講義の目的 . . . 2
1.3 講義項目と成績評価方法 . . . 2
1.4 講義形態 . . . 3
1.5 前提となる知識・項目 . . . 3

2 サイバーセキュリティ概要 (1) 5
2.1 「セキュリティ」について . . . 5
2.2 IT システムを守るとは . . . 6
2.3 情報システムの防御 . . . 7
2.4 ネットワークを介した攻撃の事例 . . . 9
2.5 Web アプリケーションと脆弱性 . . . 10
2.6 DoS 攻撃 / DDoS 攻撃 (サービス運用妨害) . . . 13
2.7 ランサムウェア . . . 15
2.8 境界型防御とセキュリティモデル . . . 16
2.9 まとめ . . . 18

3 サイバーセキュリティ概要 (2) 20
3.1 「セキュリティ」について . . . 20
3.2 情報セキュリティの要素 . . . 21
3.3 国際標準と規格 . . . 23
3.4 リスクの定義と事例 . . . 24
3.5 脆弱性 (Vulnerability) . . . 26
3.6 情報セキュリティマネジメントとポリシー . . . 28
3.7 インシデント管理と CSIRT . . . 30
3.8 東京大学の情報セキュリティ体制 . . . 32

1　授業概要

1.1　講義情報・担当講師

1.1.1　基本情報

本科目は「サイバーセキュリティ III」であり、中山雅哉氏および関谷勇司氏の 2 名体制で講義が行われます。

まとめ

科目名：サイバーセキュリティ III
担当講師：中山雅哉先生、関谷勇司先生

例え話による解説

船の航海に例えると、サイバーセキュリティという広大で危険な海域の安全な渡り方を教えてくれる、二人の熟練ナビゲーター（講師）による案内です。

1.2　講義の目的

1.2.1　組織のセキュリティ戦略と実践的対応の習得

セキュリティ技術の基礎を基盤とし、現代の組織に求められる実践的な対策を学びます。具体的には、対策の戦略立案、インシデント（事故）発生時のレスポンス体制、そして事業継続の最適解である BCP（Best Current Practice）のあり方について、理論と実際の事例を交えて理解を深めます。

まとめ

理論だけでなく実際の事例（ケーススタディ）を通じて、組織を守るための「戦略・インシデント対応・BCP」の 3 本柱を学ぶことが最大の目的です。

例え話による解説

城（組織）を守ることに例えると、城壁の作り方（理論）を学ぶだけでなく、敵が実際に攻めてきた時の迎撃手順（インシデント対応）や、城の一部が破壊されても国を維持する方法（BCP）を、過去の戦史（事例）から学ぶようなものです。

1.3　講義項目と成績評価方法

1.3.1　評価基準と学習テーマ

成績は「レポート課題」によって評価されます。講義では、概念の理解から始まり、システムの「脆弱性」、実際の「攻撃と防御」のメカニズム、「インシデント対応」、そして「認証やアクセス制御」など、多岐にわたるトピックを網羅的に学習します。

まとめ

【評価】レポート課題で成績が決まります。
【内容】脆弱性の理解から、防御、インシデント対応、認証、レジリエンスまで、守りを固めるための包括的なトピックを扱います。

例え話による解説

冒険者ギルドの昇格試験に例えられます。試験（レポート）をクリアするために、モンスターの弱点（脆弱性）の探し方、盾の正しい構え方（防御）、怪我をした時の応急処置（インシデント対応）などを幅広く身につけるトレーニングメニューです。

1.4　講義形態

1.4.1　受講スタイルとシステム

資料の配布や各種連絡は学習管理システム（UTOL）で行われます。授業は教室での「対面」と Zoom を用いた「リモート」のハイブリッド形式で提供され、原則として録画も UTOL で公開されるため復習が容易です（外部講師による非公開回を除く）。PC を用いた演習がある場合は事前に告知されます。

まとめ

プラットフォーム：UTOL を利用。
受講スタイル：対面と Zoom のハイブリッド形式、録画配信あり。
演習：PC を使用する演習があるため、事前連絡があった際は PC を準備すること。

例え話による解説

魔法の通信機（Zoom・UTOL）を使って、直接道場（教室）に行かなくても自宅から授業を受けられ、後から幻影（録画）で復習もできる便利なシステムです。たまに実技（PC 演習）があるので、その時は自分の武器（PC）を持参する必要があります。

1.5　前提となる知識・項目

1.5.1　受講に望ましい基礎知識

必須ではありませんが、「サイバーセキュリティ I」を履修済みであるか、ネットワークや OS に関する基礎知識を持っているとスムーズに学習できます。また、課題を取り組む上で、PC をネットワークに接続し、ブラウザを扱える基本的な IT リテラシーは必須となります。

まとめ

【推奨知識】ネットワーク、OS、サイバーセキュリティ I の内容（経路制御、仮想化、マルウェア、PKI など）。
【必須スキル】PC のネット接続および Web ブラウザの基本的な利用スキル。

例え話による解説

自動車の運転に例えると、交通ルールや車のエンジン構造（サイバーセキュリティ I の知識）を知っているとより安全に走れますが、最低限、自分でキーを回してハンドルを握れる（PC をネットに繋いで操作できる）ことは大前提となります。

2　サイバーセキュリティ概要 (1)

2.1　「セキュリティ」について

2.1.1　セキュリティとセーフティの違い

セキュリティとは、守らなければならない大切なものが、危害や損傷を受けない「正常な状態」にあることを指します。組織においては、構成員の生命や保有する財産を危害から守り、正常な状態を維持することが求められます。

- **セキュリティ**：侵入、盗難、攻撃、破壊など、**悪意をもって行われる人的な脅威**に対して正常な状態を確保すること。
- **セーフティ**：交通事故や災害など、**悪意の介在しない**自然現象や偶発的・突発的に発生する脅威に対する安全を確保すること。

まとめ

セキュリティとセーフティの最大の違いは「脅威に悪意があるかどうか」です。人間の悪意ある攻撃から守るのがセキュリティ、自然現象や事故から守るのがセーフティです。

例え話による解説

【家を守ることに例えると】

- **セキュリティ**：空き巣（悪意のある人間）に入られないように、玄関に頑丈な鍵をかけたり防犯カメラを設置すること。
- **セーフティ**：地震（悪意のない自然現象）で家具が倒れてこないように、タンスを壁に固定したり火災報知器を付けること。

2.1.2　各種セキュリティの定義と範囲

組織を守るためのセキュリティは、その対象や領域によって大きく 3 つに分類されます。

- **情報セキュリティ**：組織の重要な財産である「情報（情報資産）」そのものの安全を確保し、維持すること。
- **情報システムセキュリティ**：情報を扱うための「IT システム（機器やソフトウェア）」に対する安全を確保し、維持すること。
- **サイバーセキュリティ**：組織の情報システムに対し、ネットワークを介した情報窃取、改ざん、破壊、サービス妨害（DDoS 攻撃など）といった攻撃や不正行為を防ぎ、適切に保護すること。

まとめ

これらは「情報（全体）＞ IT システム（基盤）＞サイバー（ネットワーク経由の攻撃）」というように、守るべき対象のスコープ（範囲）や焦点が異なります。

例え話による解説

【銀行に例えると】

- **情報セキュリティ**：顧客の口座情報や預金データそのものが漏洩したり紛失したりしないように、業務ルールを定めて全体を管理すること。
- **情報システムセキュリティ**：銀行の ATM や行員のパソコンが壊れたり誤作動したりしないように、機器の安全を保つこと。
- **サイバーセキュリティ**：インターネットバンキングに対して、外部のハッカーが不正アクセスをして送金したり、システムをダウンさせたりするのを防ぐこと。

2.2 IT システムを守るとは

2.2.1 IT インフラの構成と大原則

IT システムを稼働させるための基盤（土台）となるのが「IT インフラ」です。IT インフラは主に以下の 3 つの要素で構成されています。

- **ハードウェア**：PC、サーバー、ストレージなどの物理的な機器
- **OS**：macOS、Windows、Linux などのオペレーティングシステム
- **ソフトウェア・アプリケーション**：アプリケーションサーバー、メール、Web サーバーなど

これらのインフラをネットワークに接続して利用する際、絶対に忘れてはならない大原則があります。それは**「ネットにつながっているということは、ネットからもつながっている」**ということです。

まとめ

IT システムはハードウェア・OS・ソフトウェアというインフラの上に成り立っています。そして、便利に外部へアクセスできるということは、同時に外部からもアクセスされるリスクを抱えているという裏返しでもあります。

例え話による解説

【家に窓やドアを作ることに例えると】インターネットに繋ぐことは、家に外の景色を見るための「窓」や、外へ出かけるための「ドア」を作るようなものです。中から外が見えて便利な反面、外からも家の中が見えたり、泥棒が侵入する入り口にもなり得ます。だからこそ、鍵（セキュリティ）が必要になります。

2.2.2 情報システムセキュリティの対象と対策

情報を扱う IT システムを守るためには、「サイバー空間（ネットワーク）」と「フィジカル空間（物理）」の両面からの対策が必要です。

守るべき対象（大学内の例）：

- 学内事務システム
- 情報公開用の Web サーバ
- 研究室や部門で管理されている NAS（ファイルサーバ・ファイル共有）

- アンケートフォームなどのアプリケーション

具体的なセキュリティ対策の目的：

- **攻撃から守る**：ネットワークを経由した外部からのサイバー攻撃、内部関係者による不正行為、機器への物理的な破壊行為を防ぐこと。
- **システムを止めない**：システムが稼働不能（サービス停止）に陥らないように維持すること。

まとめ

情報システムセキュリティとは、サイバー攻撃だけでなく物理的な破壊からもシステムを守り、常に稼働できる状態を維持することです。ただし、セキュリティに「完全（100%）」は存在しないため、被害を最小限に抑える継続的な備えが求められます。

例え話による解説

【お店の営業を守ることに例えると】

- **サイバー攻撃対策**：お店に嫌がらせの電話が大量にかかってきて通常の注文が受けられなくなる（サービス妨害）のを防いだり、顧客名簿が盗まれるのを防ぐこと。
- **フィジカル対策**：お店のガラスが割られたり、レジが物理的に破壊されたりするのを防ぐこと。
- **稼働の維持**：セキュリティに「絶対」はないため、万が一泥棒に入られても、すぐに営業を再開できるようにバックアップの資金やマニュアルを用意しておくことと同じです。

2.3 情報システムの防御

2.3.1 外部攻撃・脆弱性対策

ネットワークを介した外部からのサイバー攻撃を防ぐためには、システム自体の弱点（脆弱性）をなくし、不要な通信経路を遮断することが重要です。

- **ソフトウェア脆弱性情報の収集と対応**：JPCERT/CC や UTokyo-CERT 等のセキュリティ情報に常に注意を払い、利用中のソフトウェアに脆弱性が発見された場合はただちにアップデート等の対応を行います。また、定期的な脆弱性スキャンやペネトレーションテスト（侵入テスト）を実施します。
- **システムの欠陥排除**：システムがどのようなソフトウェアで構成されているか（構成管理）を把握し、設計や方式自体に欠陥がないか確認します。
- **アクセス範囲の限定**：不要なアクセス経路を除外して攻撃者の侵入を防ぎます。Google Drive、OneDrive、Proself 等のクラウドストレージで資料を共有する際にも公開範囲の設定に配慮が必要です。
- **ファイアウォール（UTM / WAF）の利用**：通信の内容を監視し、攻撃と判断される不正な通信を自動で遮断するセキュリティ機器を導入します。
- **ログ管理**：万が一の事態に備え、サーバ等の動作ログを正確に記録・保管しておきます。

まとめ

外部攻撃対策の基本は、「穴（脆弱性）を塞ぐ」「入り口を絞る（アクセス制限）」「関門を設ける（FW/WAF）」「行動を記録する（ログ）」の 4 点に集約されます。

例え話による解説

【お城の防衛に例えると】

- **脆弱性対策**：城壁に亀裂（欠陥）がないか定期的に点検し、見つけたらすぐに補修すること。
- **アクセス限定・WAF**：城門を必要最小限に絞り、門番（WAF）が怪しい通行人をチェックして追い返すこと。
- **ログ管理**：誰がいつ城に入ったかを門番の日誌（ログ）にしっかり記録しておくこと。

2.3.2　内部攻撃対策

システムの脅威は外部からだけでなく、正規の ID が乗っ取られた場合や、内部の人間による不正アクセス、悪意あるソフトウェアの実行によっても引き起こされます。

- **乗っ取られた ID を利用した攻撃への対策**：
  - PC やスマートフォンなどのエンドデバイスのセキュリティを強化します。
  - ユーザのセキュリティリテラシを向上させ、強力なパスワード設定や「2 要素認証」の利用を徹底します。
- **ランサムウェア対策**：エンドデバイスでの不正プログラム検知を強化し、標的型攻撃（特定の組織を狙ったメール攻撃など）からの防御を徹底します。
- **内部不正対策**：システムにアクセスできる人物の権限を必要最小限（適切な権限設定）にとどめ、不審な操作を牽制・事後確認するために「監査ログ」を保持します。

まとめ

内部脅威対策は「正規の権限を悪用されないこと」が重要です。2 要素認証による本人確認の徹底、アクセス権限の最小化、そして監査ログによる監視が有効な防衛策となります。

例え話による解説

【会社のオフィス管理に例えると】

- **ID 乗っ取り対策**：社員証や鍵（パスワード）を盗まれても、指紋やスマートフォンの認証（2 要素認証）がないとドアが開かない仕組みにすること。
- **内部不正対策**：一般社員が社長室や経理の金庫に入れないようアクセス権限を分け、金庫を開けた記録（監査ログ）を残すこと。

2.3.3　物理的破壊対策

サイバー空間での対策だけでなく、サーバやハードウェア自体が物理的に破損・停止すること（フィジカルな脅威）に対しても備えが必要です。

- **電源の二重化と停電対策**：停電や電源装置の故障に備え、電源ラインを二重化したり、無停電電源装置（UPS）や自家発電設備を利用します。
- **物理的なアクセス制限**：サーバ室への関係者以外の立ち入りを防ぐため、物理的な施錠や入退室管理を行います。
- **外部インフラの利用**：耐震・防火設備や高度な物理セキュリティを備えたデータセンターやクラウドサービスを活用し、自前で管理するリスクを低減します。

まとめ

どれほどソフトウェアのセキュリティを固めても、コンセントが抜かれたり機器が破壊されたらシステムは停止します。電源の冗長化や物理アクセス制限、強固なデータセンター・クラウドの活用で「物理的な停止」を防ぐことが不可欠です。

例え話による解説

【大切な貴重品金庫の保護に例えると】

- **電源・アクセス対策**：停電しても電子ロックが開くよう予備バッテリーを用意し、金庫室自体に頑丈な鍵をかけて不審者を近づけないこと。
- **データセンター・クラウド利用**：自宅の部屋にそのまま置いておくのではなく、災害や泥棒に強い銀行の地下大金庫（データセンター）に預けること。

2.4　ネットワークを介した攻撃の事例

2.4.1　システムへの侵入と情報窃取

ネットワークを通じてシステムの弱点を突き、内部への侵入や情報の盗み出しを図る代表的な攻撃手法です。

- **Web アプリケーション脆弱性を突く攻撃**：Web サイトや Web アプリに存在する代表的な不具合（脆弱性）を悪用し、裏側にあるデータベースから顧客情報や機密情報などを漏えいさせる攻撃です。
- **Remote Exploit（リモートエクスプロイト）**：ネットワークを経由して、OS やソフトウェアの脆弱性を遠隔から攻略する攻撃です。成功すると、攻撃者にシステム全体の制御（管理者権限など）を完全に奪われてしまいます。

まとめ

これらの攻撃は、どちらも「システムの設計ミスやプログラムの欠陥（脆弱性）」を外部から突くのが特徴です。情報をこっそり盗み出したり、システムを乗っ取って踏み台にしたりするために行われます。

例え話による解説

【お店や家に例えると】

- **Web アプリ脆弱性**：お店の受付窓口（Web サイト）での手続きの隙を突いて、奥にある顧客名簿をこっそり盗み見ること。
- **Remote Exploit**：家の壁にある見えないひび割れや鍵の欠陥（脆弱性）を外から特殊な道具でいじり、家の鍵を開けて完全に家を乗っ取ること。

2.4.2　サービスの妨害と身代金要求

システムから情報を盗むだけでなく、システムそのものを「使えなくする」ことで組織に重大なダメージを与える攻撃手法です。

- **DoS 攻撃（Denial of Service）**：標的となるサーバやネットワークに対して大量のデータや通信を送りつけ、処理能力の限界を超えさせることで、正常なサービスを利用不能（ダウン）にする攻撃です。
- **ランサムウェア攻撃**：マルウェア（悪意のあるソフトウェア）の一種で、感染したコンピュータやシステム内のデータを勝手に暗号化して使えなくします。その上で、データを元に戻すための「身代金（ランサム）」を要求する恐喝目的の攻撃です。

まとめ

情報を盗む攻撃とは異なり、こちらは「業務を停止させること」自体が脅威となります。DoS 攻撃はサービスの妨害による信用の失墜を狙い、ランサムウェアはデータの復旧を人質に金銭を要求します。

例え話による解説

【お店の営業妨害に例えると】

- **DoS 攻撃**：お店の予約電話に、嫌がらせの電話を何千回も同時にかけ続け、本当のお客さんが全く電話を繋げない状態（営業停止）にすること。
- **ランサムウェア**：夜中にお店のレジや金庫、重要なファイルに勝手に南京錠をかけ、「鍵を開けて営業を再開したければ、指定の口座にお金を振り込め」と脅迫状を貼ること。

2.5　Web アプリケーションと脆弱性

2.5.1　Web アプリケーションの仕組みとセッション管理

SNS やショッピングサイトなど、Web ブラウザを通じて操作するアプリケーションは、基本的に「Web ブラウザ　Web サーバ　データベースサーバ」の 3 階層システムで構成されています。

Web アプリケーションでは、ユーザがログインしている状態を維持（セッション管理）するために **Cookie（クッキー）**を利用します。しかし、この Cookie が盗まれると重大な被害につながります。

- **成りすましの危険性**：Cookie（SESSIONID など）が悪意ある第三者に盗まれると、サーバは「この Cookie を持っているから本人だ」と誤認し、アカウントが乗っ取られてしまいます。
- **Cookie を守るための対策**：

- **HTTPS 通信の利用**：通信経路での盗聴を防ぐため、通信を暗号化する。
- **同一オリジンポリシー**：Cookie の発行元など、指定されたドメインにのみ Cookie を送信させる仕組み。
- **Cookie 属性の適切な設定**：
  - `Secure`：HTTPS 通信時のみ送信させる。
  - `HttpOnly`：JavaScript からの読み取りを禁止し、悪意あるスクリプトから守る。
  - `domain` / `path` / `expires` / `max-age`：送信先や有効期限を厳密に制限する。

まとめ

Cookie は「あなたはログイン済みの○○さんですね」と証明するためのデジタルな入場券です。通信の暗号化（Secure）やプログラムからのアクセス禁止（HttpOnly）を正しく設定し、入場券を盗まれないようにすることが防御の第一歩です。

例え話による解説

【遊園地のリストバンドに例えると】

- **Cookie**：遊園地(Web サイト)に入場した証拠として腕に巻かれる「リストバンド(SESSIONID)」。
- **成りすまし被害**：リストバンドを奪い取って自分の腕に巻いた泥棒が、スタッフ（サーバ）にリストバンドを見せて、あなたになりすましてアトラクション（アカウント）を悪用すること。

2.5.2 クロスサイトスクリプティング (XSS)

Web サイトの入力欄や表示機能に不備があり、悪意のある JavaScript などのスクリプトが混入・実行されてしまう脆弱性を **XSS（クロスサイトスクリプティング）**と呼びます。

- **攻撃の仕組み**：攻撃者が罠となるスクリプト（例：`<script>alert(document.cookie)</script>`）を掲示板等に埋め込みます。他のユーザがそのページを見た瞬間、ブラウザ上でスクリプトが実行され、`document.cookie` で読み取られたセッション ID が攻撃者のサーバへ勝手に送信されてしまいます。
- **XSS の種類**：
  1. **反射型 (Type-1)**：攻撃用スクリプトが URL などに含まれ、サーバからそのまま反射して実行される。
  2. **格納型/持続型 (Type-2)**：攻撃用スクリプトがサーバのデータベース等に保存され、閲覧者全員に実行される。（例：掲示板やアップローダーへの書き込み）
  3. **DOM ベース型 (Type-0)**：動的にページを作る JavaScript 自体に不備があり、予期せぬスクリプトが混入する。

まとめ

XSS は「ユーザーのブラウザ上で不正なプログラムを実行させる」攻撃です。入力された文字をそのまま HTML として表示してしまう（エスケープ処理の不足）掲示板やブログ、翻訳サイトなどで発生しやすくなります。

例え話による解説

【学校の掲示板に例えると】

- **XSS 攻撃**：学校の公式掲示板に、悪意ある生徒が「この番号に電話すると良いことがあるよ !」という嘘のポスター（悪意あるスクリプト）を勝手に貼ること。
- **被害**：公式掲示板だからと信じた他の生徒（ブラウザ）が、その指示通りに行動してしまい、自分の個人情報（Cookie）を泥棒に渡してしまう状態です。

2.5.3 SQL インジェクションと主要な脆弱性

「OWASP Top 10 (2021)」でも常に上位に位置するインジェクション攻撃の代表例が、データベースを不正操作する **SQL インジェクション**です。

- **SQL とは**：データベースを操作したりデータを抽出したりするための問い合わせ言語です。
- **攻撃手法と影響**：ログイン画面のパスワード入力欄に `FOO' OR '1' = '1` という特殊な文字列を入力します。すると、サーバ側で組み立てられる SQL 文が以下のようになります。

```
SELECT ユーザid FROM ユーザDB
WHERE ユーザ名 = 'Alice' and パスワード = 'FOO' OR '1' = '1'
```

  `'1' = '1'` という条件は「常に正しい（True）」ため、パスワードが間違っていても認証を突破できてしまいます。
- **被害と防御の難しさ**：過去にはこの脆弱性を突かれて大規模なサイト改ざんや長期閉鎖（価格.com 事件など）が起きました。Web サーバやデータベースが単体で安全でも、プログラム側で入力値の無害化（エスケープ処理）を怠る「設計上の欠点」によって発生するため、適切なフレームワークの利用や厳密な検査が必要です。

まとめ

XSS が「ユーザーを狙う攻撃」であるのに対し、SQL インジェクションは「データベース（システムの中枢）を直接狙う攻撃」です。意図しない命令文をシステムに注入（インジェクト）し、データを改ざん・漏洩させます。

例え話による解説

【役所の書類申請に例えると】

- **正常な処理**：申請用紙の「名前」欄に「山田」と書いて提出し、職員が山田さんの書類を探すこと。
- **SQL インジェクション**：名前欄に「山田、それから金庫の中身を全部見せて」と書き込むこと。システム（職員）がそれをただの「名前」としてではなく「命令」として勘違いして読み上げてしまい、本当に金庫を開けてしまう状態です。

2.6 DoS 攻撃 / DDoS 攻撃 (サービス運用妨害)

2.6.1 DoS 攻撃と DDoS 攻撃の基礎

サービス運用妨害攻撃（Denial of Service）は、正常なサービスの提供を妨害・停止させる攻撃であり、一般的に完全な防護が難しい攻撃手法です。

- **攻撃が成功する 2 つの主要因：**
  1. **システムのバグ**：通常と異なる不正なリクエストを送信し、システムを不安定化・停止させる。
  2. **リソースの枯渇**：処理能力を超える過剰なリクエストを送りつけ、CPU やメモリ、ネットワーク帯域を使い果たす。
- **DoS と DDoS の違い：**
  - **DoS 攻撃**：**1 台**のコンピュータから攻撃。攻撃元 IP の特定が容易なためアクセス制限等の対策が可能だが、攻撃容量に限界がある。
  - **DDoS 攻撃**：乗っ取った**複数の PC（ボットネット）**から同時に攻撃。攻撃元 IP が多数存在するため特定・遮断が極めて難しく、膨大なデータ量での攻撃が可能。

まとめ

DoS は単一の端末から、DDoS は乗っ取った多数の端末から一斉に行う攻撃です。攻撃元が分散する DDoS は正規アクセスとの識別が難しく、IP 制限による防御が困難になります。

例え話による解説

【人気飲食店への嫌がらせに例えると】

- **DoS 攻撃**：1 人のクレーマーがレジの前で嫌がらせをして列を停滞させること。店側がその 1 人を追い出せば（IP 遮断）解決します。
- **DDoS 攻撃**：何百人ものサクラ（乗っ取られた PC）を一斉に送り込み、何も注文せずに全座席を占有させること。誰が本当のお客さんか判別できず、店は完全に営業不能（ダウン）になります。

2.6.2 OS およびインフラ層への脅威

DoS/DDoS 攻撃は特定の Web サイトだけでなく、OS の脆弱性やインターネット基盤（Root DNS や BGP 経路制御）に対しても行われます。

- **OS の DoS 脆弱性（SACK Panic: CVE-2019-11477）**：Linux の TCP 機能（TCP Selective ACK）のバグ。通信相手が極小サイズでのデータ送信を要求すると、パケット分割処理のミスにより Linux OS 自体が機能停止に陥りました（2009 年 3 月以降の全 Linux が対象）。
- **Root DNS サーバへの DDoS**：インターネット全体の名前解決を支える Root DNS への攻撃。決定的な解決策が存在しないため、BGP Anycast 等を用いて通信を分散させ、インターネット全体のダウンリスクに対応しています。
- **BGP 経路ハイジャック (BGP Hijacking)**：経路制御の「性善説」を悪用し、虚偽の経路情報を広告して通信を横取り・不達にする攻撃。

- 2010/04: 中国 ISP によるハイジャック
- 2014/02: カナダ ISP 経由で暗号通貨マイニング通信をリダイレクトし窃取
- 2017/04: ロシア Rostelecom による MasterCard、Visa 等の通信誤広告
- 2017/12: Google 等の通信がロシア DV-LINK-AS へ流出
- 2018/04: Amazon Route 53 の約 1300 IP がハイジャック
- 2019/06: 欧州モバイルトラフィックが China Telecom 経由に迂回

まとめ

基盤層への攻撃（Root DNS への DDoS や BGP 経路ハイジャック）は、特定サイトにとどまらずインターネット全体の広域障害や通信の盗聴につながる重大なリスクを持っています。

例え話による解説

【交通網やカーナビに例えると】

- **OS 脆弱性攻撃**：車のエンジン構造の欠陥を突いて、特定の合図を送るだけで一瞬でエンストさせるようなもの。
- **BGP 経路ハイジャック**：道路の案内標識（BGP）を偽物に書き換え、目的地に向かう車をすべて攻撃者のアジト（盗聴）や行き止まり（不達）へ誘導してしまうようなものです。

2.6.3 大規模サービスに対する DDoS 攻撃事例

近年では、プロトコルの仕様や増幅（リフレクション）効果を悪用し、天文学的な通信量を発生させる攻撃が相次いでいます。

- **GitHub Attack (2018 年 2 月)**：ピーク時 1.35 Tbps。Memcached のリフレクション脆弱性を悪用した攻撃で、約 20 分間 GitHub が通信不能となりました。
- **KILLNET による攻撃 (2022 年)**：ロシア系ハッカー集団「KILLNET」により、日本国内の公的機関や企業（e-Gov、eLTAX、JCB、mixi、JR 各社等）が攻撃を受けました。
- **HTTP/2 Rapid Reset 攻撃 (CVE-2023-44487, 2023 年 8 月)**：Amazon、Google、Cloudflare 等に対し、秒間 **3 億 9800 万回**のリクエストを発生させた超大規模な攻撃です。

まとめ

近年の DDoS 攻撃は、プロトコルの挙動を利用して攻撃を増幅させる技術手法（リフレクション攻撃等）や、ハッカー集団による標的型攻撃により、規模・影響ともに甚大化しています。

例え話による解説

【郵便局のパンクに例えると】

- **リフレクション / Rapid Reset 攻撃**：1 通の手紙を出すだけで「100 通の返信を送れ」と命令（増幅）したり、大量の手紙を出した直後にキャンセル処理を連発して、郵便局（サーバ）の分類処理をパニックに陥らせるような攻撃です。

2.7　ランサムウェア

2.7.1　ランサムウェアの概要

ランサムウェア（Ransomware）は、身代金を意味する「Ransom」と「Software」を組み合わせた造語であり、感染したコンピュータ内のファイルを強制的に暗号化してアクセス不能にし、その復元（解読）と引き換えに金銭を要求する悪質なマルウェアである。2017 年の「WannaCry」による世界規模の感染拡大をきっかけに、その凶悪性と脅威が広く認知されるようになった。

まとめ

ランサムウェアは「データを暗号化して解読の身代金を要求する」マルウェアであり、WannaCry の世界的流行によって脅威として広く認識された。

例え話による解説

自室のドアや金庫に勝手に強力な南京錠を取り付けられ、「部屋に入りたければ・金庫を開けたければ指定の口座にお金を振り込め」と書かれたメモを置かれるような状態です。

2.7.2　国内における主な被害事例

近年、日本国内でも業種を問わず甚大な被害が相次いで発生している。

- **製造・基幹システムへの被害（某製粉大手・2021 年 7 月）**
  基幹システム、ファイルサーバ、財務会計・販売管理システムが同時に暗号化され、決算の四半期報告書の提出期限を延長せざるを得ない事態に追い込まれた。
- **医療機関の危機（某公立病院・2021 年 10 月）**
  約 8 万 5000 人分の電子カルテ（氏名、年齢、治療履歴等）が暗号化により喪失。バックアップデータまで被害が及び、診療業務に重大な支障が生じた。
- **サプライチェーンの停止（某大手自動車部品メーカーグループ・2022 年 3 月）**
  海外拠点および取引先の感染に端を発し、連動して国内すべての工場が一時稼働停止となった。
- **情報流出と脅迫（某大手ゲームメーカー・2020 年 11 月）**
  社内グループウェアの障害にとどまらず、35 万件以上の個人情報が流出・喪失。約 11 億 5000 万円の身代金を要求されたが拒否した。
- **重要インフラ・物流の麻痺（名古屋港・2023 年 7 月）**
  名古屋港統一ターミナルシステムが停止し、貨物船の入出港作業がストップ。復旧までに 3 日間を要した。

まとめ

ランサムウェア被害は単なる PC の故障にとどまらず、医療停止・工場ストップ・港湾物流の停滞・大規模な個人情報流出など、社会生活や経済全体を麻痺させる重大なリスクとなっている。

例え話による解説

街の病院、工場、港、ゲーム会社などの「鍵」が同時に壊されてしまったような状態です。鍵が開かないために、診察が受けられなくなったり、工場で作った製品が出荷できなくなったりして、社会全体が大パニックに陥ってしまいます。

2.7.3　サイバー犯罪組織 LockBit の攻撃ポリシー

ランサムウェア攻撃で知られるサイバー犯罪組織「LockBit」は、独自の攻撃ガイドライン（犯罪ポリシー）を定めて活動している。

- **重要インフラへの制限**：発電所（原子力・火力・水力）やパイプライン、製油所などの重要インフラに対しては、ファイルの「暗号化（システム停止）」は禁止し、データの窃取（強迫材料）のみを許可している。
- **旧ソ連構成国の保護**：ロシア、ウクライナ、ベラルーシ、カザフスタン、エストニア、ラトビアなどの旧ソ連地域への攻撃は全面的に禁止している。
- **医療・教育・政府機関**：非営利組織、私立・営利目的の教育機関、政府機関への攻撃は認められている。また医療・製薬施設に対しては「死に至らない範囲」でのデータ窃取（暗号化は不可）のみ許可している。
- **法執行機関**：警察署や司法当局への攻撃はむしろ推奨されている。

まとめ

LockBit などの高度な犯罪組織は、国家的な法執行機関からの集中捜査や国際的報復を避けるため、攻撃対象や手法にルールを設けて意図的にターゲットをコントロールしている。

例え話による解説

「自国の周りは絶対に襲わない」「救急医療を完全に止めて人が死ぬと本気で警察に追い詰められるからデータ窃取にとどめる」といった、自分たちが捕まらないための“悪党なりの計算された掟”を作り、賢く・執拗に身代金を奪おうとしているイメージです。

2.8　境界型防御とセキュリティモデル

2.8.1　セキュリティモデルの比較

システムの防御アプローチは、従来の「ネットワーク境界を守る」考え方から、端末・クラウド・ID を中心とした包括的なアプローチへと進化している。

- **境界型防御モデル（従来）**：守るべき資産は「社内ネットワーク（LAN）」内にあるとし、インターネットとの境界線で検疫や VPN を導入して防護するモデル。パターンマッチング（シグネチャ）やサンドボックスに依存する。
- **エンドポイント型防御**：ネットワーク境界をすり抜けた脅威に対し、端末（PC やスマートフォン）側で直接挙動をリアルタイム監視・制御する（例：EDR、MDM）。
- **クラウド型防御**：テレワークやクラウド利用の拡大に伴い、すべての通信が必ず通過する中継ポイント

（クラウド上）で監視・集約して防御する（例：SASE）。

- **ゼロトラストアーキテクチャ**：「社内・社外を問わず一切を信頼しない」前提に立ち、アクセスごとに ID ベースで厳格に認証・認可を行い、常に最小権限で動作を制限するモデル。

まとめ

従来の「境界型」から、端末（EDR）・クラウド（SASE）・ID（ゼロトラスト）を組み合わせて常時検証する動的なセキュリティモデルへのシフトが進んでいる。

例え話による解説

昔は「城の大きな外濠と門（境界型）」で敵を防いでいましたが、内部に侵入されたり外で働く人が増えたため、「全員に常に顔写真付き身分証の提示を求め、部屋のドアごとに権限を細かくチェックする（ゼロトラスト）」仕組みに変えたイメージです。

2.8.2　ネットワークを守る PEP (Policy Enforcement Point) の構成要素

ネットワーク上のトラフィックを制御・遮断するため、各レイヤー（L2/L3/L7）で多様な機器がセキュリティポリシーの適用ポイント（PEP）として機能する。

- **スイッチ（L2）**： VLAN によるネットワーク層の隔離、MAC/IP に基づく ACL フィルタリング、各ポートの帯域制限（Bandwidth 制限）などを実施。
- **ルータ（L3）**： ACL での不正パケットのドロップ、PBR（Policy-based Routing）による経路変更のほか、以下の特殊なルーティング制御を行う。
  - **Blackhole Routing**： AS 境界などで不要・有害トラフィックを NULL 宛てに送り、破棄する。
  - **Sinkhole Routing**：特定のトラフィックを専用の検査ポイントへ引き込んで詳細解析する。
  - **Shunt Routing**： Sinkhole での検査完了後、正常なトラフィックのみを本来の正常経路に戻す。
- **ファイアウォール（Firewall / L3–L4）**： IP ヘッダやポート番号、セッション情報（ステート）に基づき通信の可否を決定する。（例：東京大学の FW ログ画面では、通信先や内容の危険度を色別表示して直感的に可視化）
- **Filtering Proxy（L7）**： Web アプリケーション通信（HTTP/HTTPS）の中身を代理受託・検査し、不正コンテンツを遮断する。

まとめ

L2 スイッチから L7 プロキシまで、レイヤーに応じた機器（PEP）を配置し、アクセス制御・帯域制限・特殊ルーティング（Blackhole/Sinkhole）を駆使してネットワークを防衛する。

例え話による解説

道路網に例えると、交差点（スイッチ）で車線を分け、高速道路のジャンクション（ルータ）で不審車両を検問所（Sinkhole）へ誘導したり行き止まり（Blackhole）へ追いやったり、料金所（FW/Proxy）でパスポートや荷物をチェックする仕組みです。

2.8.3　NIDS (Network-based IDS/IPS) と検知アプローチ

ネットワーク全体を流れるパケットをキャプチャ・解析し、不正侵入をリアルタイムで検知・防御するシステム（代表例：Snort）。主に以下の 2 つの検知手法が用いられる。

- **シグネチャ型（パターンマッチ）**：悪意あるコードや攻撃の固有パターン（例：`\x4a\x6c\x4a\x6d...` などの特定バイナリ列）を定義したデータベースと照合して検知する（例：EternalBlue 脆弱性攻撃の検知）。
- **振る舞い検知型（アノマリ検知）**：プロトコルのステートや通信統計を解析し、「通常と異なる異常な動き」を検知する。
  - 短時間におけるエラー応答パケットの急増
  - ICMP 通信量の著しい増大（ホストスキャンの検知）
  - TCP RST パケットの急増（ポートスキャンの検知）

まとめ

NIDS は既知の攻撃パターンを照合する「シグネチャ型」と、通信の偏りや異常挙動を捉える「振る舞い検知型」を組み合わせることで、多様な攻撃パターンに対応する。

例え話による解説

防犯カメラ（NIDS）が「指名手配犯の顔写真リスト（シグネチャ）」と照合しつつ、「夜中に鍵穴をガタガタ弄っている不審な動き（振る舞い）」も見逃さずにアラームを鳴らすようなイメージです。

2.9　まとめ

2.9.1　本講義の振り返り

本講義では、サイバー空間において日々発生している「ネットワークを利用した攻撃」の多様な種類、その技術的な仕組み、および実際の社会的・経済的被害の実例について包括的に学習した。

- **攻撃の種類と仕組み**：ランサムウェアや境界型・エンドポイント型に対する様々な侵入・スキャン手法の仕組みを理解した。
- **被害の解像度**：医療・物流・製造など、インフラや企業の事業継続に直結する実際のインパクトを学んだ。

まとめ

現代のサイバー攻撃は単なる情報漏洩にとどまらず、社会インフラやビジネスの停止を引き起こすため、攻撃の性質や手口を正しく理解することが防御の第一歩となる。

例え話による解説

「敵を知り百戦危うからず」の言葉通り、泥棒がどんな道具を使い、どのような経路で家に侵入してくるのか（攻撃の仕組みや実例）をしっかりと観察・把握した段階です。

2.9.2　今後の講義テーマ

今後は、攻撃の手口を踏まえた上で、組織やシステムをどのように保護・運用していくかという総合的なセキュリティ対応論へと学びを深めていく。

- **防御と技術基盤**：情報セキュリティ基本概念、システムに潜む「脆弱性」、攻撃の解析と具体的な防御策
- **運用と運用体制**：事案発生時の「インシデント対応」、適切な「認証とアクセス」制御、機密「情報を守る」手法
- **組織の耐久力**：障害・攻撃時にも事業を継続・回復させる「BCP（事業継続計画）とレジリエンス」

まとめ

今後は「敵を知る」フェーズから、「鍵の強化（脆弱性・認証）」「異常時の捜査と処置（解析・インシデント対応）」「立ち直る力（BCP・レジリエンス）」という実践的な防衛スキルの習得へと進む。

例え話による解説

侵入者の手口がわかったので、次は「頑丈な鍵を取り付ける（認証・脆弱性対策）」「防犯ブザーが鳴った時の避難・通報手順を決める（インシデント対応）」「家が壊されてもすぐに生活を立て直せる準備をする（BCP）」といった具体的な防災計画を立てていくイメージです。

3　サイバーセキュリティ概要 (2)

3.1　「セキュリティ」について

3.1.1　「セキュリティ」の基本概念と「セーフティ」との違い

セキュリティとは、守るべき大切な対象が危害や損傷を受けない「正常な状態（安全）」を確保し、維持することを指す。組織においては、構成員の生命や保有する財産の確保・維持が根幹となる。

- **セキュリティ（Security）**：侵入・盗難・攻撃・破壊など、人間による「悪意」をもって行われる意図的な脅威に対して、正常な状態を維持する取り組み。
- **セーフティ（Safety）**：交通事故や自然災害、機器の偶発的な故障など、「悪意の介在しない」自然現象や不可抗力的な脅威に対して安全を確保する取り組み。

まとめ

セキュリティの最大のポイントは「人の悪意（攻撃・盗難など）」に対抗することであり、自然災害や突発事故などの「非意図的な脅威」に対処するセーフティ（安全）とは明確に区別される。

例え話による解説

「セキュリティ」は防犯カメラや頑丈な鍵を取り付けて泥棒（悪意）から家を守る防犯対策、「セーフティ」は火災報知器や耐震補強をして地震や火災（事故・災害）から家を守る防災対策のような違いです。

3.1.2　対象に応じたセキュリティの分類

守るべき対象（資産）や脅威が発生する領域によって、セキュリティは以下のように定義される。

- **情報セキュリティ**：組織にとって重要財産である「情報（情報資産）」全般の安全を確保・維持すること。
- **情報システムセキュリティ**：情報を扱うハードウェア・ソフトウェアなどの「IT システム」自体の安全を確保・維持すること。
- **サイバーセキュリティ**：ネットワークを経由した情報窃取・改ざん・破壊・サービス妨害（DoS）といった「サイバー攻撃や不正行為」から情報システムを防御すること。

まとめ

「情報セキュリティ」は守るべき財産（情報）全般の安全を指し、「情報システムセキュリティ」はそれを格納する IT 機器、「サイバーセキュリティ」は通信網を通じた外部からの攻撃に対抗する防衛手段を指す。

例え話による解説

「情報」は守りたい極秘書類、「情報システム」はその書類を入れておく電子金庫、「サイバーセキュリティ」は金庫が繋がっているインターネット回線からハッカーが侵入してこないように監視する警備網のイメージです。

3.2　情報セキュリティの要素

3.2.1　情報セキュリティの 3 要素 (CIA)

情報セキュリティの基盤となる最も重要な 3 つの概念は、頭文字をとって **CIA** と呼ばれる。

- **機密性 (Confidentiality)**：許可された正規のユーザだけが情報にアクセスできる状態を保つこと。
- **完全性 (Integrity)**：情報が改ざんされず、正確かつ最新で保護されている状態を保つこと。
- **可用性 (Availability)**：権限を持つユーザが、必要な時にいつでも情報やシステムを利用・操作できる状態を保つこと。

まとめ

情報セキュリティは「見せない（機密性）」「書き換えさせない（完全性）」「いつでも使える（可用性）」の 3 つのバランス（CIA）を保つことが基本となる。

例え話による解説

「大切な日記帳」に例えると、錠前をかけて他人に見せないのが機密性、ページを破られたり勝手に書き書き直されたりしていないのが完全性、読みたい時にいつでも手元にあって読める状態が可用性です。

3.2.2　機密性 (Confidentiality) とプライバシー

機密性は、無権限のユーザやプロセスに対して情報が漏洩・公開されるのを防ぐ原理であり、組織は暗号化やアクセス制御、従業員教育を通じてこれを保護する。

- **データの分類と保護**：氏名や電話番号など公開されたデータ自体は直ちに機密情報とはならないが、非公開の個人情報や組織の内部情報は不正アクセスから厳重に保護すべき機密情報となる。
- **機密性とプライバシーの違い**：法律上・概念上の定義として、両者は区別される。
  - **機密性**：情報のステータスが「非公開」であり、それを外部へ漏らさず保持するという倫理的・技術的義務。
  - **プライバシー**：収集したデータを「本来の目的に限定して適切に使用する」こと。（米国の 1974 年プライバシー法、PCI DSS、GLBA 等で法的に規定）

まとめ

機密性は「情報を秘密にして漏らさない仕組み」であり、プライバシーは「集めた個人情報を勝手に別の目的へ悪用しないルール」という側面を持つ。

例え話による解説

患者のカルテを鍵付き棚にしまって部外者に見せないのが「機密性の確保」、そのカルテを病気の治療目的以外（勝手なダイレクトメールの送信など）に使わないのが「プライバシーの保護」です。

3.2.3　完全性 (Integrity)

ライフサイクル全体を通じて、データが正確であり、一貫性が保たれ、信頼できる品質を維持していることを指す。

- **必要性：**銀行・金融機関の残高・取引履歴などにおいて極めて重視され、完全性が損なわれるとデータ資産全体の信頼性が失われ、システムとして機能しなくなる。
- **保証・検証手法：**アクセス制御、入力妥当性チェック（バリデーション）、データ整合性チェックを実施する。
- **ハッシングによるチェック：**基準時点で算出しておいたハッシュ値（データの指紋）と、検証時のハッシュ値を照合することで、途中で 1 ビットでも改ざんされていないかを確認する。

まとめ

データが勝手に書き換えられていないかを担保するのが完全性であり、改ざん検知にはハッシュ値による照合が代表的な手法として用いられる。

例え話による解説

重要な契約書に割印を押しておき、後からページが差し替えられたり文字が消されたりしていないかを割印のズレ（ハッシュ値）で確認するような仕組みです。

3.2.4　可用性 (Availability)

情報システムやサービスが、災害やシステム障害が発生しても「いつでも利用できる」状態を維持する指標である。

- **高可用性システムの 3 原則：**
  1. 単一障害点（SPOF: Single Point of Failure）の排除
  2. 信頼できるクロスオーバー（予備系への切り替え機構）の提供
  3. 障害発生の迅速な検出
- **可用性を保つ 7 つの実装手法：**
  1. 機器の定期メンテナンス
  2. OS やシステムの迅速なアップデート
  3. バックアップの復元テスト
  4. 災害復旧計画（DR 計画）の策定
  5. 新規テクノロジーの導入
  6. 異常アクティビティの常時監視
  7. 可用性の定期的検証テスト

まとめ

可用性を高めるには、機器の冗長化（二重化）だけでなく、日常的なメンテナンスやバックアップテスト、異常監視といった運用面での継続的アクションが不可欠となる。

例え話による解説

電気や水道などのインフラが、台風や地震の時でも止まらないように予備の発電機を用意し、日頃から点検や避難訓練（バックアップテスト）を行っておくことと同じです。

3.2.5　さらに必要となる 4 要素

伝統的な CIA（3 要素）に加え、現代の複雑な情報社会においては以下の 4 つの要素を加えた「7 要素」としてセキュリティを定義することが多い。

- **真正性 (Authenticity)**：利用者や情報、送信元が偽物ではなく「本物」であることを証明・確保すること。
- **信頼性 (Reliability)**：システムが意図された仕様に従い、誤動作なく正確に処理を実行すること。
- **責任追跡性 (Accountability)**：「いつ・誰が・どのような操作を行ったか」という行動の痕跡をログ等で明確に記録・特定できること。
- **否認防止 (Non-Repudiation)**：後から「そんな操作や送信はしていない」と事実を主張・否定できないように証拠を残すこと。

まとめ

CIA（3 要素）に「真正性・信頼性・責任追跡性・否認防止」を加えることで、事後検証や法的立証にも耐えうる総合的なセキュリティ基盤が完成する。

例え話による解説

本人の署名・印鑑（真正性）、狂いなく動く時計（信頼性）、誰が入室したか残る防犯カメラのログ（責任追跡性）、受け取ったサイン済みの領収書（否認防止）を揃えることで、後からのトラブルを防ぐイメージです。

3.3　国際標準と規格

3.3.1　ISM 規格 (ISO/IEC 27000 シリーズ)

組織が情報セキュリティマネジメントシステム（ISMS）を構築・運用するための国際標準規格として、ISO/IEC 27000 シリーズが策定されている。

- **ISO/IEC 27000**：シリーズ全体の概要、および用いられるセキュリティ用語の定義をまとめた基本規格。
- **ISO/IEC 27001**： ISMS の「要求事項（認証基準）」を定めた核心規格。組織が ISMS を構築・運用・監視・維持・継続的に改善するためのルールが規定されている。
- **ISO/IEC 27002**：情報セキュリティ管理策（コントロール）の「実践規範（コード・オブ・プラクティス）」。ISO/IEC 27001 に基づく具体的なセキュリティ対策の実装・運用に関するガイドラインを提供する。

まとめ

ISO/IEC 27000 シリーズは、27000（用語辞書）、27001（守るべきルール・認証基準）、27002（具体的な対策の手引き）のように、役割を分担して組織のセキュリティ管理体制を支えている。

例え話による解説

「車の免許テスト」に例えると、27000 は交通用語集、27001 は合格するための試験基準（ルール）、27002 は具体的な安全運転のハンドブック・コツ集のような関係です。

3.3.2　ISO/IEC 27001 の構造と運用体制

ISO/IEC 27001 は、組織全体で計画的かつ継続的にセキュリティを高めるフレームワーク構造をとっている。

- **標準的な規格構造：**主に「4 組織の状況」「5 リーダーシップ」「6 計画」「7 支援」「8 運用」「9 パフォーマンス評価」「10 改善」の各章で構成されている。
- **PDCA サイクルによる継続的改善：**一度構築して終わりではなく、Plan（計画）→ Do（実行）→ Check（評価・点検）→ Act（改善）のサイクルを回し続けることで、変化する脅威に対応する。
- **国内の評価機関（JIPDEC）：**日本国内においては、一般財団法人日本情報経済社会推進協会（JIPDEC）が ISMS 適合性評価制度の運営機関として認証の信頼性を担保している。

まとめ

ISO/IEC 27001 はトップの「リーダーシップ」のもと、PDCA サイクルを継続的に回すことで、組織のセキュリティ水準を維持・向上させる仕組みである。日本では JIPDEC が認定制度を運営している。

例え話による解説

健康診断を受けて（Check）、生活習慣を改善し（Act）、新しい運動計画を立てて（Plan）、毎日実行する（Do）という「健康管理のループ」を組織全体で組織的に行う仕組みです。

3.4　リスクの定義と事例

3.4.1　リスクの定義と構成要素

セキュリティにおけるリスクとは、単一の要素ではなく **「資産」「脅威」「脆弱性」** の 3 つが重なり合うポイントで発生・顕在化する。

- **リスクの掛け算構造：**「守るべき資産の価値」×「外部からの脅威」×「システム等の脆弱性（弱点）」が揃った時に、損失をもたらすリスクとなる。
- **具体的事例（マイホーム）：**資産（住居の価値）× 脆弱性（可燃性の木材構造）× 脅威（火災・放火）＝リスク（住居焼失による重大な損害）
- **具体的事例（オンラインバンキング）：**情報資産（預金 100 万円）× 脆弱性（推測されやすいパスワード）× 脅威（サイバー攻撃者）＝リスク（不正送金被害）

まとめ

リスクは「資産（守りたいもの）」「脅威（攻撃や災害）」「脆弱性（弱点）」の 3 要素が揃った際に発生するため、防御策を講じる際はこれらのいずれかを軽減・遮断することが基本となる。

例え話による解説

大雨（脅威）が降っても、お気に入りの服（資産）を着ておらず、傘（防護策）に穴が開いて（脆弱性）いなければ服は濡れません。しかし「高額なスーツ（資産）」を着て「穴の空いた傘（脆弱性）」を持ち「大雨（脅威）」に遭うと、スーツが台無しになる（リスク）という関係性です。

3.4.2　パスワードを狙った攻撃手法と保護技術

認証情報を奪う代表的な攻撃手法と、ハッシュ化における防御技術（ソルト）の役割は以下の通りである。

- **ブルートフォース攻撃（総当たり攻撃）：**あらゆる文字の組み合わせを順次試す手法。近年の計算能力の飛躍的向上により、短く単純なパスワードは瞬時に解読される。
- **辞書型攻撃：**単語帳に載っている単語や、過去に漏洩したパスワードリストを用いて効率的に解読を試みる手法。
- **パスワード漏洩の事例（Slack・2022 年 8 月）：** Shared Invitation Link（共有招待リンク）機能のバグにより、ハッシュ化されたパスワードが約 5 年間にわたり露出・漏洩していたことが判明した。
- **ソルト（Salt）による保護：**パスワードのハッシュ化時にランダムな文字列（ソルト）を付加する手法（例: `SHA512-CRYPT`）。同じパスワードでもユーザーごとに異なるハッシュ値が生成されるため、辞書攻撃や事前計算による解読を防ぐ。

まとめ

パスワード攻撃（総当たり・辞書攻撃）に対しては、文字列の長さを確保するだけでなく、システム側で「ソルト」を付加して適切にハッシュ化しておくことが不可欠である。

例え話による解説

ダイヤル式の鍵を『0000』から『9999』まで片っ端からカチカチ回して開けるのが「ブルートフォース攻撃」、よく使われる『1234』や『8888』から優先して試すのが「辞書攻撃」、同じ合言葉でも人ごとに秘密の隠し味（ソルト）を混ぜて複雑化しておくのが「ソルト」技術です。

3.4.3　攻撃者の侵入アプローチ（行動イメージ）

攻撃者が組織の内部環境やシステムへ侵入する際のアプローチは、大きく 2 つの形態に分類される。

- **ID/パスワードの窃取：**正規の認証情報を盗み出し、システムの「正面玄関」から堂々と入ってくるイメージの攻撃。
- **脆弱性攻撃：**ソフトウェアや設定の不備・不具合を突き、建付けの悪くなった「壊れかけた裏木戸の鍵」を無理やりこじ開けて侵入するイメージの攻撃。

まとめ

攻撃の手法は「正規の認証情報を盗んで正面突破する」か「システムの弱点（脆弱性）を突いて裏口から忍び込む」かの大きく 2 パターンに集約される。

例え話による解説

泥棒が住人の合鍵を盗んで正門から何食わぬ顔で入ってくるのが「ID/パスワード窃取」、古くなって鍵がガタついている勝手口の隙間を工具でこじ開けて入ってくるのが「脆弱性攻撃」のイメージです。

3.5 脆弱性 (Vulnerability)

3.5.1 脆弱性の定義と分類

脆弱性とは、情報システム、運用手順、内部統制、あるいはソフトウェアの実装等に存在するセキュリティ上の「弱点（バグ等）」であり、情報の機密性・完全性・可用性が損なわれる要因となる。脆弱性は技術分野だけでなく、多角的に分類される。

- **設備面の脆弱性**：建物の構造上の欠陥、設備メンテナンスの不備、物理的な入退室管理システムの不備など。
- **技術面の脆弱性**：ネットワーク構成の不備、ソフトウェアのバグ、アクセス制御設定のミス、不十分なパスワード運用、マルウェア対策の欠落など。
- **管理面・制度面の脆弱性**：セキュリティ方針・規定の不備、機器・記憶媒体の管理不備、ユーザー教育の不足、インシデント対応計画や監視・監査体制の未整備など。

まとめ

脆弱性はプログラミングのバグ（技術面）だけでなく、物理的な建物の不備（設備面）や規律・教育の不足（管理面）など、組織のあらゆる領域に潜んでいる。

例え話による解説

家に例えると、窓の鍵が壊れているのが「技術面」、フェンスが低くて簡単に乗り越えられるのが「設備面」、家族が「出かける時に鍵を閉めるルール」を守っていないのが「管理面」の脆弱性です。

3.5.2 ソフトウェア脆弱性の識別・評価基準

世界中で発見されるソフトウェアの脆弱性を一元的に把握し、適切な対策の優先順位を決定するために、各種の共通識別・評価基準が運用されている。

- **CWE (Common Weakness Enumeration)**：バグや欠陥の「種類（分類）」を識別するための共通基準。
- **CVE (Common Vulnerabilities and Exposures)**：個別製品に存在する具体的な脆弱性ごとに発行される一意識別番号（例: `CVE-2023-XXXX`）。米 MITRE 社が採番・管理している。日本国内では JPCERT/CC と IPA が共同運営する「JVN (Japan Vulnerability Notes)」が情報を提供している。
- **CVSS (Common Vulnerability Scoring System)**：脆弱性の深刻度を 0 ～ 10.0 の数値で定量

評価する手法。基本評価基準（Base）、現状評価基準（Temporal）、環境評価基準（Environmental）の 3 つから構成される。

- **CVSS v3 深刻度レベル：**
  - **緊急 (9.0–10.0)**：ネットワーク経由で遠隔から攻撃可能で、特殊な条件や認証が不要かつ影響が非常に甚大な状態。
  - **重要 (7.0–8.9)**
  - **警告 (4.0–6.9)**
  - **注意 (0.1–3.9)**
  - **なし (0)**

まとめ

脆弱性は CVE によって「世界共通の背番号」が振られ、CVSS スコア（0.0〜10.0）によって危険度・優先度が数値化されることで、迅速かつ正確な対応が可能となる。

例え話による解説

病気の診断に例えると、「CWE」が病気のジャンル（風邪、骨折など）、「CVE」が患者ごとのカルテ番号、「CVSS」が「熱が 40 度あって即入院が必要（緊急）」といった危険度のスコア表です。

3.5.3　ソフトウェア以外の脆弱性と対策

セキュリティ対策はソフトウェアの修正（パッチ適用）のみならず、ネットワーク構成、物理的環境、人的要素に至るまで多層的に講じる必要がある。

- **1. ネットワーク構成の脆弱性と対策：**
  - **課題**：同一セグメントへの公開/内部サーバの混在、無防備な無線 AP やハブの設置、機器の冗長化や帯域制御の不足。
  - **対策**：適切なネットワークセグメント分割、L2 スイッチの空きポートロック、機器冗長化や帯域制御の導入。
- **2. 建物・サーバ室の脆弱性と対策：**
  - **課題**：サーバ室の無施錠、共用エリアへの機材設置、入退室記録の欠落、停電・瞬電時の機器不整合や電子錠の予期せぬ開錠。
  - **対策**：施錠管理区画の設置、来訪者・入退室管理と防犯カメラの設置、UPS（無停電電源装置）や CVCF の導入。
- **3. 人に関連する脆弱性と対策：**
  - **課題**：機密情報の漏洩・無許可持ち出し、端末の紛失、データ消去を行わないままの機器廃棄。
  - **対策**：就業規則における守秘義務の明記、情報の持ち出し・取り扱い・廃棄に関する運用手順の明確化と教育。

まとめ

物理的な侵入やネットワークの設計不備、人の過失や不正といった「プログラム外の脆弱性」に対しても、セグメント分割・物理鍵や監視カメラ・運用規程といった包括的な対策が必要である。

例え話による解説

どんなに強固な金庫（ソフトウェア）を買っても、受付を通らず誰でも金庫室に入れて（物理的脆弱性）、Wi-Fi の電波が外までダダ漏れで（ネットワーク脆弱性）、社員が金庫の番号をメモして持ち歩いていたら（人的脆弱性）意味がない、ということです。

3.6　情報セキュリティマネジメントとポリシー

3.6.1　マネジメントと PDCA サイクル

情報セキュリティ対策は、一回限りのシステム導入や一時的な注意喚起のみで完了するものではなく、組織的・体系的に取り組む必要がある。脅威の変化やシステムの更新に対応するため、**PDCA サイクル ** を繰り返すことでセキュリティ水準の維持および継続的改善を図る。

- **Plan（計画）**：組織のセキュリティ方針策定、リスク評価、対策計画の立案。
- **Do（導入・運用）**：計画に基づいた対策の導入・実施、従業員への教育・訓練。
- **Check（点検・評価）**：運用状況の点検、定期的な内部監査、ログの監視・評価。
- **Act（見直し・改善）**：点検・監査結果に基づいた不備の是正やポリシーの見直し・改善。

まとめ

情報セキュリティマネジメントは一度構築して終わりではなく、PDCA サイクル（計画・運用・点検・改善）を継続的に回すことで、組織全体の防衛力を維持・向上させる取り組みである。

例え話による解説

「健康管理や筋トレ」と同じです。目標と計画を立て（Plan）、トレーニングを実行し（Do）、体重や数値をチェックして成果を確認し（Check）、メニューを調整して改善する（Act）という循環を止めることなく続けることで、安全な体（健全な組織）を維持できます。

3.6.2　情報セキュリティポリシーのピラミッド構造

組織におけるセキュリティルール（情報セキュリティポリシー）は、抽象度や対象範囲に応じて 3 層のピラミッド構造として体系化される。

- **基本方針（最上位）**：組織が情報セキュリティに取り組む基本姿勢、理念、目的を明文化し、内外に宣言する最上位の規定。
- **対策基準（中位）**：基本方針を実現するために、組織全体または対象分野ごとに「何を遵守すべきか」を規定した具体的なルール。
- **実施手順・運用規則等（最下位）**：対策基準を日常業務で実践するために、対象者や利用システム・用

途に応じて「どのように操作・実行するか」を詳細に定めたマニュアル・手順書。

まとめ

ポリシーは「基本方針（理念・宣言）」「対策基準（具体ルール）」「実施手順（操作マニュアル）」の 3 階層で構成され、上位の方針から現場の具体的な行動手順へ落とし込まれる。

例え話による解説

「国の法体系」に例えると、基本方針が『憲法』、対策基準が『法律』、実施手順が『現場での取扱規則やマニュアル』にあたります。大元の方針から現場の細かな行動手順までが階層的に網羅されているイメージです。

3.6.3　ポリシー策定上の注意事項

実効性のあるポリシーを策定するためには、解釈の曖昧さを排除し、現場で迷いなく運用できるように明確化することが不可欠である。

- **対象情報資産の明確化**：保護すべきデータや機器、システムの範囲を明確にする。
- **適用対象者の明確化**：役員、正社員、契約社員、派遣社員、外部委託先など、誰に適用されるかを明記する。
- **目的・罰則の明確化**：規則の目的を示すとともに、違反時の罰則（就業規則との連動など）を明示する。
- **主体の明確化**：「誰が」「何を」行うのか、権限と責任の主体を定義する。
- **運用方法の明確化**：申請手続きや承認フロー、例外対応の手順などを具体化する。

まとめ

ポリシー策定では「対象・適用者・責任者・目的・罰則・手順」を曖昧にせず明確化することが、形骸化を防ぎルールとして機能させるために極めて重要である。

例え話による解説

「家庭内の掃除ルール」を作るときに『家をきれいにすること』とだけ書かれても誰も動きません。『毎週日曜日に（いつ）、長男が（誰が）、自分の部屋の床を掃除機でかける（何を）。破ったらお小遣い減額（罰則）』と明確にするのと同じです。

3.6.4　情報資産の洗い出しと管理

適切なセキュリティ対策を行うための第一歩は、組織が保有する情報を「資産」として正しく特定し、そのライフサイクル全体を通じて管理することである。

- **資産の特定と目録（台帳）作成**：保有する情報資産およびその管理責任者を特定し、漏れのない「情報資産管理台帳」を作成・維持する。
- **ライフサイクルに応じた管理規程**：情報の発生から破棄に至る各フェーズに応じた取り扱いルールを明確にする。
    1. **取得・作成**：機密性に応じた格付け（重要度分類）の付与。

2. **保存・保管**：暗号化、アクセス権限の設定、保管場所の施錠。
3. **利用・持出し**：外部持ち出し時の事前承認手続き、端末の暗号化。
4. **削除・廃棄・返却**：復元不可能なデータ消去、機器の物理破壊、退職・契約終了時の返却管理。

まとめ

情報セキュリティ管理の原点は「資産および管理責任者の特定（台帳化）」であり、情報の作成から廃棄までのライフサイクル全体に渡る運用ルールを定めることが求められる。

例え話による解説

図書館で本を貸し出す際に、すべての本に番号をつけて台帳（目録）を作り、入荷（作成）から保管・貸出（利用）、古くなった本の廃棄まで一貫して追跡・管理するイメージです。

3.7　インシデント管理と CSIRT

3.7.1　CSIRT と SOC の概要と連携体制

セキュリティインシデントに迅速に対処し、被害を最小限に抑えるためには、監視と対応の役割分担を明確にした専門組織の設置が不可欠である。

- **CSIRT (Computer Security Incident Response Team)**：インシデント発生時に対応全般を主導し、情報を集約して CISO（最高情報セキュリティ責任者）や監督官庁・外部機関へ迅速に報告・連絡する組織。平常時は脅威情報の収集・共有および緊急事態への事前備えを実施する。
- **SOC (Security Operation Center)**：ネットワーク機器やサーバー等のログを 24 時間 365 日体制で監視・分析し、異常や侵入の兆候を検知した際に CSIRT へエスカレーション（通知・連携）を行う組織。

まとめ

SOC が日々のログ監視で異常を発見して伝達し、連絡を受けた CSIRT がインシデント対応の指揮・調査・対外報告を担うという密接な連携体制により組織の安全が維持される。

例え話による解説

SOC は「防犯モニター画面を 24 時間監視する警備員」、CSIRT は「警備員から通報を受けて現場へ駆けつけ、現場指揮・犯人の特定・警察への報告を行う緊急対応チーム」という役割分担です。

3.7.2　CSIRT の主な役割と機能分類

CSIRT の活動範囲は、実際のインシデント処理にとどまらず、技術解析・連携・教育・組織運用まで多岐にわたる。

- **情報管理・共有**：外部からの最新脅威情報の収集・分析、他組織や業界団体との情報共有。
- **経営層連携**： CISO などの経営者へ直ちに報告し、意思決定をサポートするラインの確立。
- **インシデント対応機能の専門化**：

  - **コマンダー**：対応全体を統括・指揮する責任者。
  - **ハンドラー**：現場での各種対応作業の進行管理・調整役。
  - **トリアージ**：被害の深刻度や緊急性を判断し、優先順位を割り振る役割。
  - **フォレンジック**：事故原因の解明や法的証拠保全のためのデジタル解析。
- **組織基盤の維持**：社内セキュリティ教育の実施、組織運営手続きの維持、システム運用との調整。

まとめ

CSIRT は単一の役割ではなく、指揮（コマンダー）・優先度仕分け（トリアージ）・原因分析（フォレンジック）などの専門的機能を持ち、経営層との連携や社員教育までを担う総合的なセキュリティ組織である。

例え話による解説

病院の救急救命チームに例えると、搬送された患者の緊急度を診る（トリアージ）、手術の指揮を執る（コマンダー）、病因を精密検査する（フォレンジック）、普段から予防医療の指導をする（教育）といった専門的機能を備えた体制です。

3.7.3　インシデントハンドリングの標準フロー

セキュリティインシデントが発生した際は、あらかじめ定義された段階的な手順（ハンドリングフロー）に従って対応を進める。

1. **検知・連絡受付**： SOC からのエスカレーション、システムアラート、社員や外部からの連絡によって異変を迅速に検知し、受付・記録する。
2. **トリアージ**：発生したインシデントの影響範囲や緊急度、ビジネスへの影響量を初期評価し、対応の優先順位を決定する。
3. **インシデントレスポンス**：被害拡大を防ぐための一次対応（隔離や通信遮断）、原因調査・フォレンジック解析、影響を受けたシステムの復旧作業を実行する。
4. **報告・情報公開**：経営者（CISO）、被害者・関係者、行政・各種監督官庁へ正確に報告し、必要に応じてプレスリリース等を通じた対外公表や二次被害防止情報の提供を行う。

まとめ

インシデントハンドリングは「検知・受付 → トリアージ（仕分け）→ レスポンス（封じ込め・復旧）→ 報告・公開」の標準プロセスを踏むことで、被害の抑止と適切な情報共有を達成する。

例え話による解説

消防署の火災対応に例えると、119 番通報を受け（検知）、火事の規模や危険度を判断し（トリアージ）、消防隊が出動して消火・救助活動を行い（レスポンス）、鎮火後に火災原因や被害状況を警察やニュース等へ報告・発表する（報告・公開）という一連の流れと同じです。

3.8　東京大学の情報セキュリティ体制

3.8.1　東京大学における情報セキュリティポリシーの構成

東京大学（本学）の情報セキュリティポリシーは、セキュリティの標準的なピラミッド構造に基づき、公開範囲や用途に応じた 3 階層の体系として整備・運用されている。

- **基本方針（最上位）**：本学のセキュリティに対する基本理念や姿勢を示すものであり、広く一般に向けて「学外公開」されている。
- **対策基準（中位）**：基本方針を遵守するための全 13 項目からなる具体的な規則。運用の安全性を担保するため「学内限定公開」とされている（例：組織・体制、情報の分類と管理、事案への対応、自己点検・監査など）。
- **実施手順（最下位）**：現場における具体的な作業手順や運用ルール。利用環境や技術分類ごとに細分化され、多岐にわたり整備されている（例：情報分類・管理編、サーバ編、クラウドサービス編、在宅勤務編、ログ管理編など）。

まとめ

東京大学のセキュリティポリシーは、「基本方針（学外公開）」「対策基準（学内限定・13 項目）」「実施手順（各環境ごとの具体手順）」の 3 階層で構成されており、全学の様々な環境に応じたルールが具体化されている。

例え話による解説

学校の規則に例えると、一般の人にも公開されている学校の教育方針・理念が「基本方針」、校内でのみ共有されるテストや部活の基準が「対策基準」、実験室やパソコン室などの利用マニュアルが「実施手順」というイメージです。

3.8.2　東京大学の CSIRT 体制 (UTokyo-CERT)

大規模かつ多様な研究・教育組織を持つ東京大学では、全学レベルと各部局レベルが緊密に連動した階層的な CSIRT 体制（UTokyo-CERT）を構築している。

- **全学組織のライン**：総長を頂点とし、最高情報セキュリティ責任者（CISO）の統括のもと、全学 CSIRT である「UTokyo-CERT」が全学的なインシデント対応や統括を行う。
- **各部局組織のライン**：学部や研究所などの各部局においても、部局長 → 部局 CISO → 部局 CERT → 専攻等 CERT という現場に即した対応連携ラインが整備されている。

まとめ

東京大学のインシデント対応体制（UTokyo-CERT）は、全学を統括するトップダウンのライン（総長・CISO・UTokyo-CERT）と、各学部や研究所の現場を守る部局ラインが密接に連携する構造となっている。

例え話による解説

都道府県の防災組織に例えると、全体を統括する「消防庁本部（全学 CISO・UTokyo-CERT）」と、各地域を守る「地元の消防署（部局 CISO・部局 CERT）」がしっかり連携して、広大なキャンパス全体の危機に即座に対応するイメージです。